



UNIVERSITÀ
DEGLI STUDI
FIRENZE

Scuola di Ingegneria

Corso di Laurea Triennale
in Ingegneria Informatica

Valutazione e confronto di OWASP, CIS e MITRE per la mitigazione delle vulnerabilità online

Candidato:

Filippo Mauro Grazzini

Relatore:

Prof. Enrico Boni

Correlatore:

Prof. Tommaso Pecorella

Anno Accademico 2023/2024

Indice

Introduzione	2
1 Stato dell'arte	4
1.1 OWASP	4
1.1.1 Overview di OWASP	4
1.1.2 Valutazione delle qualità di OWASP	9
1.1.3 Analisi dei difetti di OWASP	10
1.2 CIS	12
1.2.1 Overview di CIS	12
1.2.2 Valutazione delle qualità di CIS	13
1.2.3 Analisi dei difetti di CIS	16
1.3 MITRE ATT&CK	16
1.3.1 Overview di MITRE ATT&CK	19
1.3.2 Analisi dei difetti di MITRE ATT&CK	22
2 Confronto tra i Framework di Sicurezza	24
2.1 Confronto dei principali aspetti	24
3 L'utopia di un Documento di Sicurezza Universale	31
Conclusioni	33
Appendici	34
Bibliografia	35
Ringraziamenti	36

Introduzione

Oggi più che mai, la rapidità dell'evoluzione tecnologica rappresenta un fenomeno senza precedenti. In meno di un secolo siamo passati da macchine enormi e rudimentali, come l'ENIAC, che richiedevano intere stanze per funzionare, a dispositivi incredibilmente compatti e potenti, come gli smartphone, che sono ormai una costante nella nostra vita. Questo salto evolutivo non solo ci ha permesso di accedere a tecnologie sempre più avanzate, ma ha anche trasformato profondamente il nostro modo di vivere, lavorare e comunicare. Tuttavia, dietro a questi progressi si cela una sfida complessa: la capacità di adattamento.

L'innovazione tecnologica viaggia oggi a una velocità tale che la capacità umana di adattarsi è costantemente messa alla prova. Ogni nuovo dispositivo, sistema operativo o software non è solo un'opportunità per migliorare le nostre vite, ma rappresenta anche una potenziale vulnerabilità. Ogni innovazione apre nuove porte a possibilità straordinarie, ma allo stesso tempo crea punti d'accesso per possibili minacce, soprattutto nell'ambito della sicurezza informatica. Un esempio concreto di questa realtà è il mondo degli smartphone. La rapidità con cui vengono introdotti nuovi modelli significa che spesso i vecchi dispositivi non ricevono più aggiornamenti di sicurezza adeguati. Questo li rende terreno fertile per hacker e cybercriminali. Non appena un sistema viene considerato sicuro, emergono nuovi metodi per aggirarlo. È una sorta di corsa agli armamenti tra innovatori e malintenzionati: per ogni nuova tecnologia progettata per proteggere i dati, c'è qualcuno che lavora per superarla.

Il problema si amplifica quando guardiamo alle infrastrutture più complesse, come i sistemi aziendali o le reti governative. Non è raro che una vulnerabilità venga scoperta e corretta, solo per poi trovarne altre che emergono subito dopo. Questo fenomeno, noto come "patching costante", obbliga le aziende a destinare enormi risorse alla manutenzione e alla protezione dei sistemi, senza mai raggiungere una sicurezza totale. Un ulteriore fattore di complicazione è dato dall'integrazione crescente di tecnologie basate sull'Intelligenza Artificiale. L'IA offre strumenti potentissimi per prevenire attacchi, ad esempio tramite il rilevamento delle minacce basato su modelli predittivi. Tuttavia, la stessa IA viene sfruttata dai cybercriminali per sviluppare attacchi sempre più sofisticati. Ad esempio, gli algoritmi di deep learning possono essere utilizzati per generare attacchi mirati, come phishing estremamente realistici, che rendono difficile anche per un utente esperto riconoscerli.

Questa dinamica mette in evidenza un paradosso: più avanziamo tecnologicamente, più diventiamo dipendenti da sistemi che, per quanto sofisticati, non sono mai completamente al sicuro. La digitalizzazione globale ha moltiplicato i vantaggi, ma ha anche creato un'interconnessione che espone a rischi sistemici. Un attacco informatico a una grande piattaforma non colpisce solo una singola azienda, ma può avere effetti a catena su milioni di persone. Un altro esempio emblematico è facilmente individuabile prendendo in considerazione internet: ogni dispositivo ad esso connesso, dagli elettrodomestici alle automobili, rappresenta un punto d'accesso potenziale. Una falla in un dispositivo apparentemente innocuo, come una

videocamera di sicurezza domestica, può permettere a un malintenzionato di entrare in reti più complesse, con conseguenze imprevedibili.

La rapidità con cui il mondo evolve ci impone una riflessione. Non possiamo permetterci di fermare l'innovazione, ma dobbiamo imparare a gestirla in modo più consapevole. Investire in formazione e aggiornamento continuo è fondamentale: le competenze che consideriamo sufficienti oggi potrebbero non esserlo più domani. Parallelamente, è essenziale promuovere una cultura della sicurezza informatica, che non si limiti a pochi esperti del settore ma coinvolga ogni utente. Inoltre, è necessario trovare un equilibrio tra innovazione e sostenibilità. La frenesia di rilasciare nuovi prodotti e aggiornamenti non può venire a scapito della qualità e della sicurezza. Forse, anziché inseguire costantemente l'ultima novità, dovremmo concentrarci sul miglioramento e sulla protezione di ciò che già possediamo. In conclusione, la velocità del progresso tecnologico è una straordinaria opportunità, ma ci richiede un impegno altrettanto straordinario per affrontare le sfide che inevitabilmente porta con sé. Solo così potremo sfruttarne appieno il potenziale, senza esserne travolti.

In questa tesi, confronterò in dettaglio tre differenti framework dedicati alla sicurezza informatica, analizzandone punti di forza e debolezza. L'obiettivo sarà identificare quali caratteristiche rendono ciascun framework efficace nel rispondere alle sfide attuali e quali invece rappresentano limiti o mancanze che ne compromettono l'applicabilità in determinati contesti. Attraverso questa analisi, nella parte conclusiva della tesi cercherò di delineare come potrebbe essere strutturato un documento di sicurezza informatica veramente completo ed efficace, in grado di combinare i punti di forza dei tre framework, eliminandone al contempo le criticità. Questo approccio non solo consentirà di proporre una visione più integrata e funzionale della sicurezza informatica, ma offrirà anche spunti pratici per migliorare i sistemi già esistenti, a fronte di un panorama tecnologico in continua evoluzione.

Capitolo 1

Stato dell'arte

In questo capitolo analizzeremo tre standard fondamentali per la sicurezza informatica: OWASP, CIS e MITRE. Ognuno di questi si concentra su aspetti specifici dello stesso grande obiettivo: contrastare gli attacchi informatici in modo efficace. OWASP è incentrato sulla sicurezza delle applicazioni web, ovvero quei software eseguiti all'interno di browser web e comunemente identificati come siti web, fornendo linee guida chiare per sviluppatori e aziende.

CIS, invece, adotta un approccio più ampio, focalizzandosi sulla sicurezza dell'architettura informatica. Con il termine "architettura" si intende l'insieme delle interazioni tra i vari componenti di un sistema, comprese applicazioni, server, reti e dispositivi.

MITRE, infine, offre un contributo cruciale concentrandosi sul fornire consapevolezza sulle modalità operative degli attaccanti. Questo framework non solo documenta le tecniche, le tattiche e i procedimenti utilizzati dai cybercriminali, ma fornisce anche strumenti pratici per analizzare la resilienza del proprio sistema. Attraverso l'adozione di strumenti come MITRE ATT&CK e MITRE CALDERA, è possibile valutare se un sistema è adeguatamente protetto contro specifici tipi di attacchi e definire strategie di difesa mirate.

1.1 OWASP

OWASP (Open Web Application Security Project) è una realtà no-profit che si occupa di dare consapevolezza alle organizzazioni che lavorano nello sviluppo di applicazioni web. OWASP offre risorse, strumenti e guide per aiutare le organizzazioni a sviluppare e mantenere il loro software sicuro. La sua missione è sensibilizzare ed educare le aziende e gli sviluppatori sui rischi di sicurezza che possono minacciare le applicazioni web e fornire loro le informazioni necessarie per prevenire vulnerabilità. Nel seguito, esploreremo una panoramica del progetto OWASP, ne valuteremo i punti di forza e analizzeremo le sue potenziali limitazioni.

1.1.1 Overview di OWASP

I motivi per cui OWASP è così celebre nel mondo informatico sono principalmente tre:

- **La documentazione wstg** sulla consapevolezza informatica, un file github che contiene la quasi totalità delle vulnerabilità web conosciute, come è possibile verificarne la presenza nelle proprie applicazioni e, in qualche caso, qualche contromisura. Ciò che è stato descritto è mostrato nella figura 1.1.

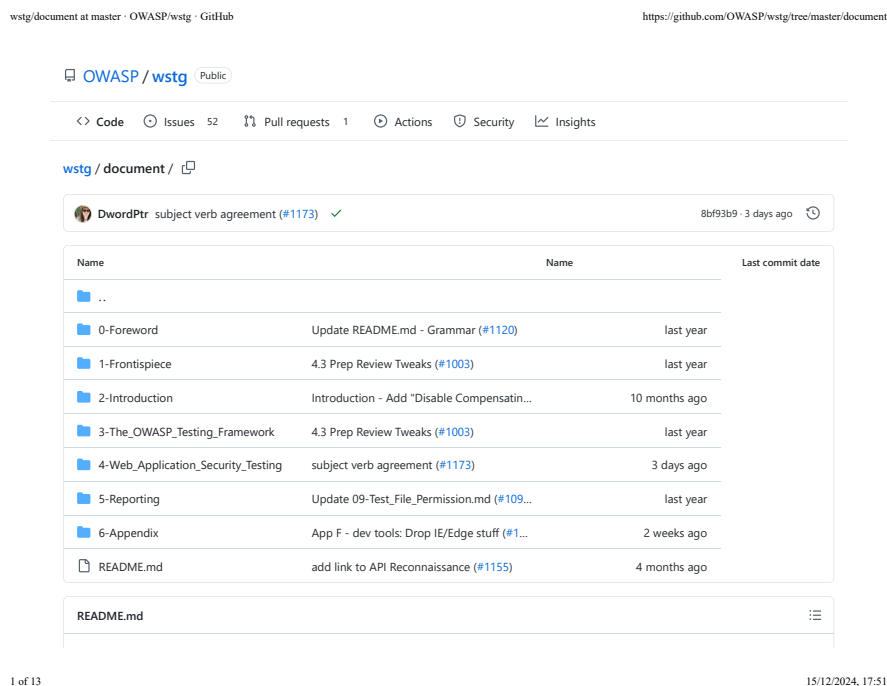


Figura 1.1: Repository github di OWASP wstg.

- **ZAP (Zed Attack Proxy)**, uno strumento ad hoc per i test sopra citati: funzionando effettivamente come un proxy, intercetta il traffico verso e dalla propria applicazione web. Ciò che è stato descritto è mostrato nella figura 1.2.
- **OWASP Top 10**, una lista dinamica aggiornata ogni 3/4 anni che include le 10 vulnerabilità di sicurezza più critiche riscontrabili nei siti web. Ciò che è stato descritto è mostrato nelle figure 1.3 e 1.4.

In questa Tesi verrà trattato il documento di cyber sicurezza di OWASP, il quale racchiude moltissime vulnerabilità web e per ognuna di esse ne spiega il funzionamento, con che strumenti individuarle e se (e come) sono contrastabili.

Il documento sulla cybersecurity di OWASP è diviso in moltissime sezioni che affrontano una alla volta tutti i temi di maggior importanza riguardanti la sicurezza delle applicazioni web. Gli argomenti sono trattati in maniera lineare partendo sempre da un riassunto: così facendo il lettore avrà sempre una conoscenza base del tipo di vulnerabilità di cui parlerà il capitolo; proseguono spiegando l'obiettivo dei test e come testare il programma. Il capitolo termina, quando necessario, con una spiegazione su come rimediare alla vulnerabilità e quali strumenti utilizzare. Ciò che è stato descritto è mostrato nelle figure 1.5, 1.6, 1.7 e 1.8.

Durante lo studio del documento WSTG di OWASP, ho riscontrato molte ridondanze e individuato alcuni modi per migliorare la lettura, rendendola più piacevole, semplice e comprensibile. Ho quindi iniziato a ristrutturare e riassumere il documento proposto da questa azienda, arrivando alla creazione di tre documenti: il primo è un vero e proprio riassunto di OWASP nel quale, oltre ad averlo tradotto in italiano, ho eliminato le parti più lunghe e aggiunto alcune sezioni non sempre presenti, ma che ritengo molto importanti, come per esempio la sezione "Rimedi", che era presente solamente in alcuni capitoli; il secondo è una lista degli strumenti utilizzati negli esempi proposti dal documento; infine, il terzo consiste in vari consigli tratti dal

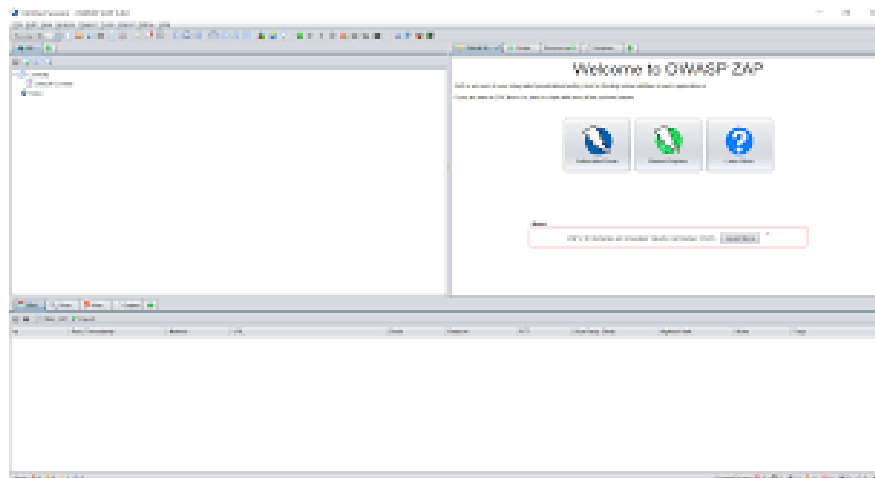


Figura 1.2: Homepage di OWASP ZAP.

OWASP Top 10:2021

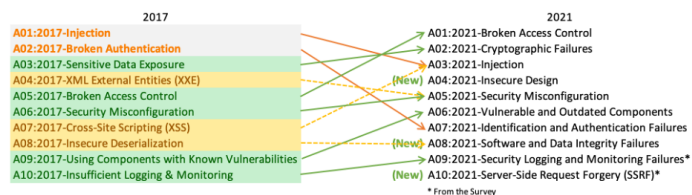
<https://owasp.org/Top10/>

Welcome to the latest installment of the OWASP Top 10! The OWASP Top 10 2021 is all-new, with a new graphic design and an available one-page infographic you can print or obtain from our home page.

A huge thank you to everyone that contributed their time and data for this iteration. Without you, this installment would not happen. **THANK YOU!**

What's changed in the Top 10 for 2021

There are three new categories, four categories with naming and scoping changes, and some consolidation in the Top 10 for 2021. We've changed names when necessary to focus on the root cause over the symptom.



- **A01:2021-Broken Access Control** moves up from the fifth position to the category with the most serious web application security risk; the contributed data indicates that on average, 3.81% of applications tested had one or more Common Weakness Enumerations (CWEs) with more than 318k occurrences of CWEs in this risk category. The 34 CWEs mapped to Broken Access Control had more occurrences in applications than any other category.
- **A02:2021-Cryptographic Failures** shifts up one position to #2, previously known as **A3:2017-Sensitive Data Exposure**, which was broad symptom rather than a root cause. The renewed name focuses on failures related to cryptography as it has been implicitly

2 of 10

15/12/2024, 18:35

Figura 1.3: OWASP Top 10 - parte 1.

- before. This category often leads to sensitive data exposure or system compromise.
- **A03:2021-Injection** slides down to the third position. 94% of the applications were tested for some form of injection with a max incidence rate of 19%, an average incidence rate of 3.37%, and the 33 CWEs mapped into this category have the second most occurrences in applications with 274k occurrences. Cross-site Scripting is now part of this category in this edition.
 - **A04:2021-Insecure Design** is a new category for 2021, with a focus on risks related to design flaws. If we genuinely want to "move left" as an industry, we need more threat modeling, secure design patterns and principles, and reference architectures. An insecure design cannot be fixed by a perfect implementation as by definition, needed security controls were never created to defend against specific attacks.
 - **A05:2021-Security Misconfiguration** moves up from #6 in the previous edition; 90% of applications were tested for some form of misconfiguration, with an average incidence rate of 4.5%, and over 208k occurrences of CWEs mapped to this risk category. With more shifts into highly configurable software, it's not surprising to see this category move up. The former category for **A4:2017-XML External Entities (XXE)** is now part of this risk category.
 - **A06:2021-Vulnerable and Outdated Components** was previously titled Using Components with Known Vulnerabilities and is #2 in the Top 10 community survey, but also had enough data to make the Top 10 via data analysis. This category moves up from #9 in 2017 and is a known issue that we struggle to test and assess risk. It is the only category not to have any Common Vulnerability and Exposures (CVEs) mapped to the included CWEs, so a default exploit and impact weights of 5.0 are factored into their scores.
 - **A07:2021-Identification and Authentication Failures** was previously Broken Authentication and is sliding down from the second position, and now includes CWEs that are more related to identification failures. This category is still an integral part of the Top 10, but the increased availability of standardized frameworks seems to be helping.
 - **A08:2021-Software and Data Integrity Failures** is a new category for 2021, focusing on making assumptions related to software updates, critical data, and CI/CD pipelines without verifying integrity. One of the highest weighted impacts from Common Vulnerability and Exposures/Common Vulnerability Scoring System (CVE/CVSS) data mapped to the 10 CWEs in this category. **A8:2017-Insecure Deserialization** is now a part of this larger category.
 - **A09:2021-Security Logging and Monitoring Failures** was previously **A10:2017-Insufficient Logging & Monitoring** and is added from the Top 10 community survey (#3), moving up from #10 previously. This category is expanded to include more types of failures, is challenging to test for, and isn't well represented in the CVE/CVSS data. However, failures in this category can directly impact visibility,

Figura 1.4: OWASP Top 10 - parte 2.

wstg/document/4-Web_Application_Security_Testing/11-Client-side_Testing/04-Testing_for_...https://github.com/OWASP/wstg/blob/master/document/4-Web_Application_Security_Testing...

OWASP / wstg

<> Code

Issues 52

Pull requests 1

Actions

Security

Insights

master

wstg / document / 4-Web_Application_Security_Testing / 11-Client-side_Testing / 04-Testing_for_Client-side_URL_Redirect.md

Go to file

ThunderSon and kingthorin

Review Pre-4.2 (#635)

c711255 · 4 years ago

64 lines (42 loc) · 3.14 KB

Preview

Code

Blame

Raw

Testing for Client-side URL Redirect

ID
WSTG-CLNT-04

Summary

This section describes how to check for client-side URL redirection, also known as open redirection. It is an input validation flaw that exists when an application accepts user-controlled input that specifies a link which leads to an external URL that could be malicious. This kind of vulnerability could be used to accomplish a phishing attack or redirect a victim to an infection page.

This vulnerability occurs when an application accepts untrusted input that contains a URL value and does not sanitize it. This URL value could cause the web application to redirect the user to another page, such as a malicious page controlled by the attacker.

This vulnerability may enable an attacker to successfully launch a phishing scam and steal user credentials. Since the redirection is originated by the real application, the phishing attempts may have a more trustworthy appearance.

Figura 1.5: Esempio di riassunto di un capitolo di OWASP.

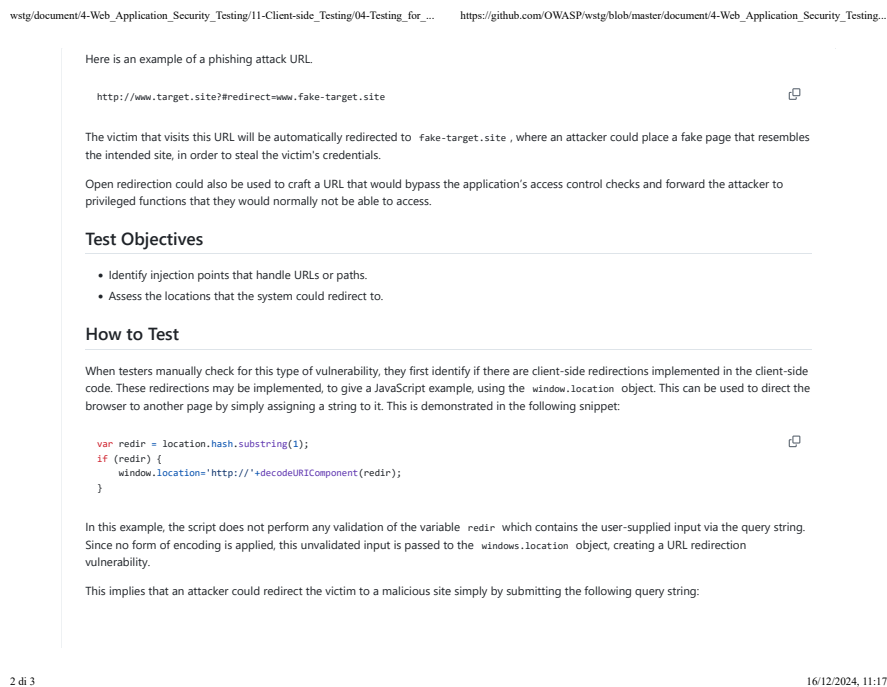


Figura 1.6: Esempio degli obiettivi di test di un capitolo di OWASP.

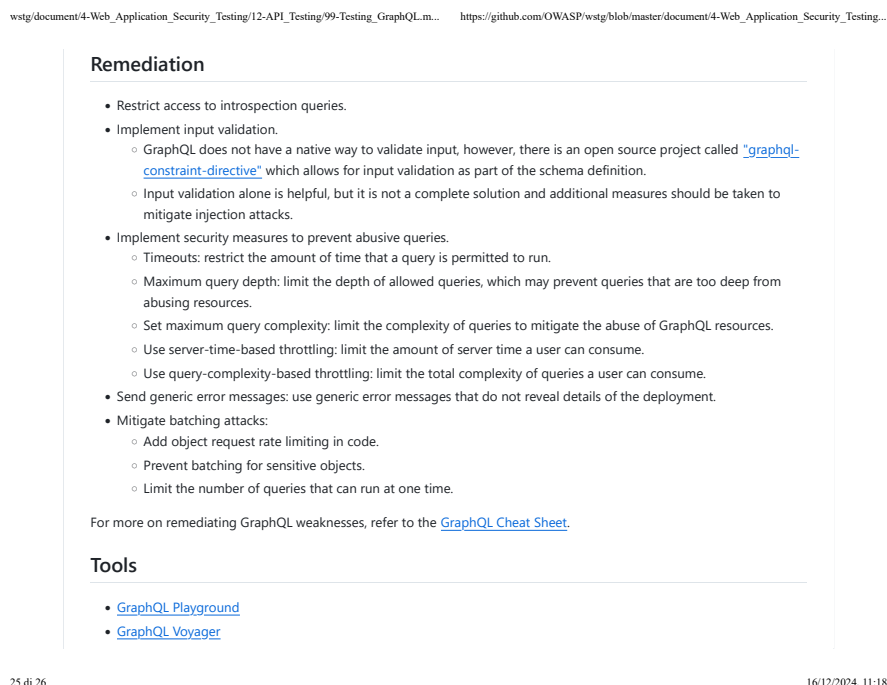


Figura 1.7: Esempio di strumenti e rimedi di un capitolo di OWASP.

- [sqlmap](#)
- [InQL \(Burp Extension\)](#)
- [GraphQL Raider \(Burp Extension\)](#)
- [GraphQL \(Add-on for ZAP\)](#)

References

- [poc-graphql](#)
- [GraphQL Official Site](#)
- [Howtographql - Security](#)
- [GraphQL Constraint Directive](#)
- [Client-side Testing \(XSS and other vulnerabilities\)](#)
- [5 Common GraphQL Security Vulnerabilities](#)
- [GraphQL common vulnerabilities and how to exploit them](#)
- [GraphQL CS](#)

Figura 1.8: Esempio di riferimenti a siti esterni di un capitolo di OWASP.

documento completo, pensati per i programmatori. In quest'ultimo documento non vengono fornite spiegazioni, ma solo linee guida. Chi fosse interessato ad approfondire uno di questi consigli può facilmente ritrovarlo nel documento completo grazie alla numerazione dei capitoli. Questi documenti si trovano in un repository pubblico su GitHub, il cui link è riportato nelle appendici in fondo alla tesi.

1.1.2 Valutazione delle qualità di OWASP

Tenendo conto di tutti e tre i framework che andremo ad analizzare in questa tesi, OWASP è l'unico che va sempre a segno per quanto riguarda *i contenuti che tratta*: i veri **errori** che si possono trovare non sono attribuibili ad una stesura errata del documento di per sé (errori grossolani dovuti a sviste o approssimazioni), bensì a mancanze vere e proprie. Se in OWASP c'è qualcosa di sbagliato è perché non è proprio presente.

Per chiarire meglio su cosa sarà basato il giudizio proposto, il metro di valutazione di questi documenti si divide nelle seguenti categorie:

- Comprensione della vulnerabilità.
- Spiegazione su come testare la presenza della vulnerabilità.
- Presenza e completezza di strumenti per attuare i test.
- Tutorial con video ad hoc su come usare gli strumenti di test.
- Pagine create appositamente per ogni tipo di vulnerabilità nelle quali sia possibile tranquillamente testare gli strumenti di test senza ripercussioni permanenti sul proprio programma o sul nostro sistema operativo.

```
<form action="http://example.com/login">
  <label for="username">User:</label> <input type="text" id="username" name="username" value=""/><br />
  <label for="password">Password:</label> <input type="password" id="password" name="password" value=""/>
  <input type="submit" value="Login"/>
</form>
```

Example 3: Cookie Containing Session ID Sent over HTTP

The Session ID Cookie must be transmitted over protected channels. If the cookie does not have the [secure flag](#) set, it is permitted for the application to transmit it unencrypted. Note below the setting of the cookie is done without the Secure flag, and the entire log in process is performed in HTTP and not HTTPS.

```
https://secure.example.com/login

POST /login HTTP/1.1
Host: secure.example.com
[...]
Referer: https://secure.example.com/
Content-Type: application/x-www-form-urlencoded
Content-Length: 188

HTTP/1.1 302 Found
Date: Tue, 01 Dec 2013 21:18:55 GMT
Server: Apache
Set-Cookie: 35E5320KID=8D99F321233AF69593EDF52B123858DA; expires=Fri, 01-Jan-2014 00:00:00 GMT; path=/; domain=example.com; htt
Location: private/
Content-Length: 0
Content-Type: text/html

http://example.com/private

GET /private HTTP/1.1
Host: example.com
[...]
Referer: https://secure.example.com/login
Cookie: 35E5320KID=8D99F321233AF69593EDF52B123858DA;

HTTP/1.1 200 OK
Content-Type: text/html; charset=UTF-8
Content-Length: 738
Date: Tue, 25 Dec 2013 00:00:00 GMT
```

Example 4: Password Reset, Change Password or Other Account Manipulation over HTTP

If the web application has features that allow a user to change an account or call a different service with credentials, verify all of those interactions use HTTPS. The interactions to test include the following:

3 di 4

16/12/2024, 17:21

Figura 1.9: Sezione del codice nel progetto OWASP.

- Chiarimento su che modifiche apportare alla propria applicazione per porre rimedio alla falla nella sicurezza, in caso la vulnerabilità in questione sia presente.

I capitoli che vanno formando il documento di OWASP spiegano in modo efficace il concetto di vulnerabilità e come verificare se un programma ne è affetto. attraverso i capitoli 'Summary' e 'How to test'. La spiegazione è chiara e ben strutturata, arricchita da strumenti visivi come frammenti di codice e immagini, alcune delle quali derivano da tentativi reali su programmi vulnerabili. Ciò che è stato descritto è mostrato nelle figure 1.9 e 1.10.

Inoltre, la sezione dedicata agli strumenti di testing, la quale è una peculiarità di questo framework, risulta particolarmente utile per chi desidera esercitarsi nel rilevare vulnerabilità su siti non sicuri.

1.1.3 Analisi dei difetti di OWASP

È importante sottolineare che il documento OWASP non è concepito per fornire un codice pronto all'uso privo di lacune, ma si propone di offrire una comprensione fondamentale delle vulnerabilità, sensibilizzando il lettore sulla loro esistenza. Il documento spiega come verificare se il proprio codice è vulnerabile a una specifica minaccia, senza tuttavia fornire di sua iniziativa un sito vulnerabile su cui effettuare attacchi di test.

Individuare falle nei capitoli di OWASP è un compito arduo: essendo un progetto open-source attivo dal 2001, copre una vasta gamma di argomenti estremamente eterogenei, tutti trattati nel dettaglio. La spiegazione dei concetti è sempre esaustiva e, in alcuni casi, la ripetizione degli stessi porta persino a una certa ridondanza. Per affrontare questa complessità, ho intrapreso un lavoro di traduzione e adattamento dell'intero file OWASP in italiano, riassumendolo e organizzandolo in tre documenti distinti: il primo, "Riformulazione OWASP", è il documento completo di traduzione e aggiunta in tutti i capitoli della sezione "Rimedi", non sempre

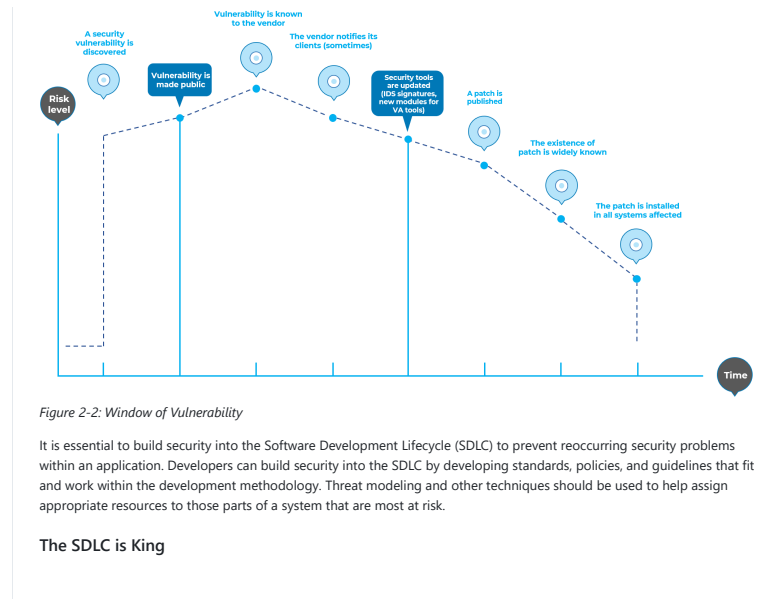


Figura 1.10: Esempio di immagine nel progetto OWASP.

presente nel documento originale; il secondo si chiama "Strumenti" ed è la lista di tutti gli strumenti praticamente utili per mettere in pratica ciò che è stato appena letto; il terzo si chiama "Programmatore" ed è semplicemente un ulteriore riassunto di "Riformulazione OWASP" nel quale non vengono date spiegazioni ma solamente consigli utili a programmatori per rendere il loro lavoro più sicuro da attacchi esterni. Se poi qualcuno fosse interessato ad approfondire le motivazioni, potrebbe benissimo controllare nel file esteso grazie alla corrispondente nomenclatura dei capitoli. Questo lavoro è stato reso disponibile pubblicamente nel mio repository GitHub (https://github.com/filograzzo/Tesi_Triennale_Cybersecurity).

L'iniziativa è stata apprezzata dalla ditta per cui ho svolto il tirocinio, in quanto la traduzione e riformulazione hanno semplificato l'accesso alle informazioni per un pubblico con difficoltà nella lingua inglese, o che semplicemente vuole evitare di spendere un'infinità di tempo per la lettura del file originale; per la sola lettura, infatti, sono necessarie dalle due alle tre settimane, dato per scontato che si legga per otto ore al giorno, come da normale giornata lavorativa. Inoltre, mi sono posto l'obiettivo di mantenere questa traduzione in futuro, allineandola alle eventuali modifiche introdotte nelle nuove versioni del progetto OWASP, in modo da garantirne l'aggiornamento continuo.

Questo lavoro potrebbe anche rappresentare un punto di partenza per una collaborazione con la comunità OWASP stessa. Contribuire direttamente al progetto, ad esempio ampliando la sezione dedicata ai "rimedi", fornire la guida in altre lingue o creare un sito sicuro sul quale poter mettere in pratica gli insegnamenti appena appresi nel documento, potrebbe migliorare ulteriormente la qualità del documento.

Come accennato nel paragrafo precedente, i veri punti deboli di questo framework derivano da carenze strutturali. In particolare, manca uno spazio dedicato alla sperimentazione degli strumenti che lo stesso OWASP mette a disposizione (come ZAP). Questa lacuna, nonostante l'esistenza di video tutorial online, limita la curva di apprendimento necessaria per utilizzare

questi strumenti a un livello avanzato.

Un'ultima critica riguarda un aspetto intrinseco della struttura del documento OWASP: la scelta di concentrarsi esclusivamente sulla sicurezza delle applicazioni web. A prima vista, questa decisione potrebbe sembrare di poco conto o giustificabile, considerando la popolarità e l'importanza crescente di queste applicazioni. Tuttavia, tale approccio presenta implicazioni significative, soprattutto se messo a confronto con framework di sicurezza più generali, come CIS e MITRE, che abbracciano una visione più ampia.

La specializzazione di OWASP ha indubbiamente permesso all'organizzazione di raggiungere un livello di dettaglio e competenza eccezionale nel suo settore di riferimento. Questo focus esclusivo ha reso il framework un punto di riferimento imprescindibile per chi lavora sulla sicurezza delle applicazioni web, fornendo strumenti, linee guida e best practice altamente dettagliate. Tuttavia, questa stessa specializzazione limita la capacità di affrontare minacce che riguardano applicazioni non strettamente web-based, ma comunque esposte su Internet.

È fondamentale chiarire questa distinzione nel contesto delle applicazioni non-web. Ad esempio, sistemi come applicazioni desktop, dispositivi IoT, server API o altre soluzioni software possono essere accessibili via Internet e, pertanto, vulnerabili a molte delle stesse minacce affrontate da applicazioni web. Framework più ampi come CIS e MITRE affrontano tali problematiche, includendo scenari di sicurezza che spaziano dal livello hardware al software non specificamente legato al web.

L'approccio OWASP, sebbene valido per il suo scopo, rischia dunque di lasciare scoperte lacune significative in ambienti dove le applicazioni non-web giocano un ruolo cruciale. Questo è un punto che dovrebbe essere evidenziato per rendere chiaro che la sicurezza informatica non si limita al contesto delle applicazioni web, ma richiede un'analisi che abbracci una gamma più vasta di sistemi e tecnologie.

1.2 CIS

Il **CIS (Center for Internet Security)** è un'organizzazione no-profit focalizzata sulla creazione di linee guida e standard di sicurezza per aiutare organizzazioni e aziende a proteggere i propri sistemi informatici. Il CIS sviluppa e fornisce risorse per affrontare le minacce emergenti e migliorare la sicurezza attraverso pratiche comprovate e standardizzate.

1.2.1 Overview di CIS

Le due principali risorse offerte dal CIS sono:

- **CIS Controls**, una serie di 18 controlli di sicurezza organizzati in priorità per ridurre al minimo i rischi informatici. Questi controlli forniscono linee guida pratiche e implementabili. Ciò che è stato descritto è mostrato nella figura 1.11.
- **CIS Benchmarks**, una serie di configurazioni di sicurezza definite come standard per proteggere sistemi operativi, software e dispositivi. I CIS Benchmarks sono lunghi pdf (circa 100 pagine l'uno) sviluppati da esperti di settore che forniscono configurazioni ottimali per ridurre le superfici di attacco. Nei quasi 25 anni dalla sua fondazione, ha spinto molto in questa direzione e ha reso i Benchmarks la sua punta di diamante.

Ad oggi comprende più di 100 pdf suddivisi in categorie: dalla protezione del sistema operativo installato sulla nostra macchina fino al software, non tralasciando neanche dei dispositivi mobili.

- [Contributing](#)

CIS Controls

- [CIS Control 1: Inventory and Control of Enterprise Assets](#)
- [CIS Control 2: Inventory and Control of Software Assets](#)
- [CIS Control 3: Data Protection](#)
- [CIS Control 4: Secure Configuration of Enterprise Assets and Software](#)
- [CIS Control 5: Account Management](#)
- [CIS Control 6: Access Control Management](#)
- [CIS Control 7: Continuous Vulnerability Management](#)
- [CIS Control 8: Audit Log Management](#)
- [CIS Control 9: Email and Web Browser Protections](#)
- [CIS Control 10: Malware Defenses](#)
- [CIS Control 11: Data Recovery](#)
- [CIS Control 12: Network Infrastructure Management](#)
- [CIS Control 13: Network Monitoring and Defense](#)
- [CIS Control 14: Security Awareness and Skills Training](#)
- [CIS Control 15: Service Provider Management](#)
- [CIS Control 16: Application Software Security](#)
- [CIS Control 17: Incident Response Management](#)
- [CIS Control 18: Penetration Testing](#)

 [latest](#)

Figura 1.11: Elenco dei controlli del framework CIS.

Sul sito ufficiale sono presenti sia le prime versioni che quelle nuove, in caso qualcuno fosse interessato a studiare lo sviluppo di tali standard. Ciò che è stato descritto è mostrato nelle figure 1.12 e 1.13.

I **CIS Controls** e i **CIS Benchmarks** vengono aggiornati regolarmente per far fronte alle nuove minacce e vulnerabilità. In particolare, i CIS Controls sono organizzati in modo dinamico e riflettono le best practice attuali di cybersecurity, proponendo un approccio scalabile e adattabile alle esigenze specifiche delle organizzazioni.

Dato che **CIS Controls** e **CIS Benchmarks** sono complementari tra loro e nessuno dei due prevale sull'altro o funge da semplice strumento accessorio (come, ad esempio, ZAP per OWASP o la Top 10, che è solo una lista di vulnerabilità già incluse nel documento principale), entrambi saranno considerati nell'analisi che presenterò nei capitoli successivi.

1.2.2 Valutazione delle qualità di CIS

CIS risulta essere molto squilibrato in quanto a qualità nella stesura: i **CIS Benchmarks** sono veramente lunghi, complessi e soprattutto incredibilmente utili anche per un novizio del campo: nel sito dedicato è possibile trovare tantissimi pdf divisi nelle rispettive sezioni, e per ogni sezione ci sono sia le nuove versioni che quelle oramai superate. Al contrario, i **CIS Controls** presentano notevoli lacune, ma questo aspetto sarà approfondito nella sezione dedicata alle criticità del framework. Ciò che è stato descritto è mostrato nella figura 1.13.

All'interno di ogni pdf possiamo trovare un indice utilissimo per la navigazione del file. Non tutti infatti potrebbero essere interessati alla sicurezza completa di un dispositivo ma solo ad un suo particolare. Ciò che è stato descritto è mostrato nella figura 1.14.

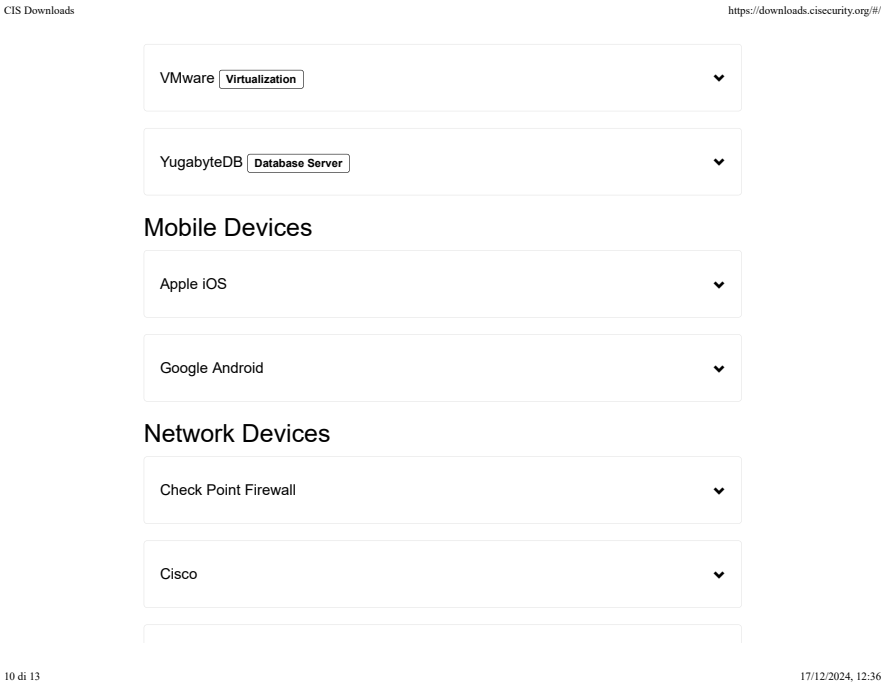


Figura 1.12: Categorie dei benchmark del framework CIS.

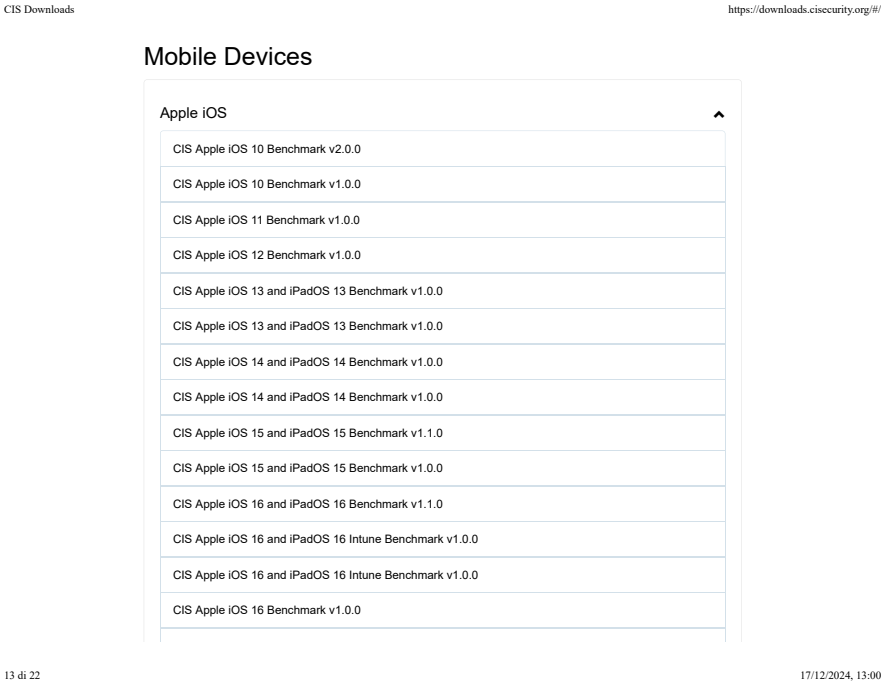


Figura 1.13: Versioni PDF dei benchmark del framework CIS.

3 Network Settings	26
3.1 (L1) Disable Network Prefetch (Manual)	27
3.2 (L1) Disable NTLM v1 (Automated)	29
3.3 (L1) Disable WebRTC (Automated)	31
3.4 (L2) Enable IDN Show Punycode (Automated)	33
3.5 (L1) Set File URI Origin Policy (Automated)	34
3.6 (L1) Validate Proxy Settings (Manual)	35
4 Encryption Settings	36
4.1 (L1) Block Mixed Active Content (Automated)	37
4.2 (L2) Set OCSP Response Policy (Automated)	39
4.3 (L2) Set OCSP Use Policy (Automated)	41
4.4 (L1) Set Security TLS Version Maximum (Automated)	43
4.5 (L1) Set Security TLS Version Minimum (Automated)	45
4.6 (L2) Set SSL Override Behavior (Automated)	47
5 JavaScript Settings	49
5.1 (L1) Block Pop-up Windows (Automated)	50
5.2 (L1) Disable Closing of Windows via Scripts (Automated)	51
5.3 (L1) Disable Displaying JavaScript in History URLs (Automated)	52
5.4 (L1) Disable Moving or Resizing of Windows via Scripts (Manual)	53
5.5 (L1) Disable Raising or Lowering of Windows via Scripts (Manual)	55
6 Privacy Settings	57
6.1 (L2) Configure New Tab Page (Manual)	58
6.2 (L1) Disabled Browser Sign-ins (Manual)	61
6.3 (L1) Disable Firefox Shield Studies (Manual)	62
6.4 (L2) Disable Form Fill Assistance (Manual)	64
6.5 (L1) Disable Geolocation Services (Automated)	66
6.6 (L1) Disable Pocket (Manual)	67
6.7 (L1) Disable Sending Data (Manual)	69
6.8 (L1) Disallow Credential Storage (Automated)	70
6.9 (L1) Do Not Accept Third Party Cookies (Automated)	71
6.10 (L1) Enable Enhanced Tracking Protection (Manual)	73
6.11 (L1) Enable Tracking Protection (Automated)	74
6.12 (L1) Set Delay for Enabling Security Sensitive Dialog Boxes (Automated)	76
6.13 (L1) Disabled Delete Data Upon Shutdown (Manual)	78
7 Extensions and Add-ons	80
7.1 (L1) Disable Auto-Install of Add-ons (Automated)	81
7.2 (L1) Disable Development Tools (Manual)	83
7.3 (L1) Disable Encrypted Media Extensions (Manual)	85
7.4 (L1) Disable Popups Initiated by Plugins (Automated)	86
7.5 (L1) Disabled Recommended Extensions (Manual)	88
7.6 (L1) Enable Extension Auto Update (Automated)	90
7.7 (L1) Enable Extension Block List (Automated)	92
7.8 (L1) Enable Extension Update (Automated)	94
7.9 (L1) Enable Warning for External Protocol Handler (Automated)	96
7.10 (L1) Set Extension Update Interval Time Checks (Automated)	97
8 Malware Settings	99
8.1 (L1) Block Reported Attack Sites (Automated)	100
8.2 (L1) Block Reported Web Forgeries (Automated)	101
8.3 (L1) Enable Cryptomining Protection (Manual)	103

Figura 1.14: Indice dei benchmark del framework CIS.

Per concludere, ogni sezione del pdf è essenziale ma esaustiva, conferendo al lettore tutto ciò che necessita su un particolare argomento. Ciò che è stato descritto è mostrato nella figura 1.15.

Un plauso che voglio fare a CIS è che non si focalizza solamente su applicazioni web come invece fa OWASP, aiutando anche nella sicurezza di Sistemi Operativi o Servizi Cloud.

Per riassumere, i CIS Benchmarks sono "manuali" dettagliati e specifici che coprono una vasta gamma di tecnologie e forniscono istruzioni passo-passo per configurare i sistemi in modo sicuro. Questo approccio semplifica notevolmente il lavoro degli amministratori di sistema e dei responsabili della sicurezza, riducendo il rischio di errori umani, non solo in ambito web ma per quanto riguarda la macchina in generale.

1.2.3 Analisi dei difetti di CIS

I lettori più attenti si staranno chiedendo come mai non c'è nessun cenno dei CIS Controls nella sezione dedicata ai pregi. Il perché è presto detto: al contrario dei CIS Benchmarks, i CIS Controls sono fatti veramente male.

Anche se qualcuno tralasciasse la difficoltà del semplice navigare tra le pagine del sito di CIS, che sembra un labirinto dal quale è difficilissimo sbrogliarsi (e purtroppo ciò vale anche per orientarsi nella ricerca dei Benchmarks), lo stesso lettore rimarrebbe alquanto deluso da cosa si trova al concludersi di questa ricerca. Egli infatti viene accolto da una lista di soli 18 punti suddivisi in altre poche microcategorie (5 di media) che sono sia estremamente corti che eccessivamente vaghi. La pagina che si apre innanzi a noi è nella quasi totalità dei casi troppo corta e scritta come se a leggerla debba essere un computer e non un essere umano: assegnando frasi a variabili e poi facendo operazioni con queste. Va da sé che la comprensione della vulnerabilità è impossibile in un paragrafo così esiguo, e questo coadiuva l'incomprensibilità dell'insieme.

Come se non bastasse, non sono forniti strumenti di test o quantomeno tutorial per verificare se le nostre implementazioni, eseguite seguendo le istruzioni dei Benchmark, siano corrette o meno, lasciandoci un po' con le mani in mano nella consapevolezza che anche un errore che a noi potrebbe sembrare banale, potrebbe magari influire sulla funzione di ciò che abbiamo appena implementato in maniera da noi non preventivata. Ciò che è stato descritto è mostrato nelle figure 1.16, 1.17 e 1.18.

Come già accennato prima, infine, un'altra limitazione che a primo impatto potrebbe non sembrare tale ma che di fatto lo è, ad esempio per un lettore casuale che vorrebbe raggiungere velocemente solo ed esclusivamente la vulnerabilità che gli interessa, è la confusione del sito.

CIS infatti, forse nascondendosi dietro alla molteplicità di servizi che offre, tralascia la semplicità di navigazione che sicuramente allontana la maggior parte dei visitatori casuali.

1.3 MITRE ATT&CK

MITRE ATT&CK è un'iniziativa globale per documentare e condividere tattiche, tecniche e procedure utilizzate dagli attori delle minacce informatiche. Questo framework offre una **documentazione granulare sugli attacchi informatici** che consente alle organizzazioni di comprendere il comportamento degli attaccanti e migliorare le proprie strategie di difesa.

A differenza di OWASP, che si concentra principalmente sulla sicurezza delle applicazioni web, MITRE ATT&CK si estende al software in generale e adotta un approccio simile a quello

2.4 (L1) Set Update Wait Time Prompt (Automated)

Profile Applicability:

- Level 1

Description:

This setting determines the amount of time, in seconds, which the system will wait before displaying the Software Update dialogue box (after an unobtrusive alert has already been shown).

Rationale:

Encouraging the user to update software as soon as possible mitigates the risk that a system will be left vulnerable.

Impact:

For this preference to have an effect `app.update.enabled` must be true.

Audit:

Ensure that `app.update.promptWaitTime` is set to 172800:

1. Type `about:config` in the address bar
2. Type `app.update.promptWaitTime` in the filter
3. Configure the setting as prescribed.

Remediation:

To establish the recommended configuration, set `app.update.promptWaitTime` to 172800:

1. Type `about:config` in the address bar
2. Type `app.update.promptWaitTime` in the filter
3. Configure the setting as prescribed.

OR

1. Open the `mozilla.cfg` file in the installation directory with a text editor
2. Add the following lines to `mozilla.cfg`:

```
lockPref("app.update.promptWaitTime", 172800);
```

Default Value:

691200

Figura 1.15: Esempio di pagina dei benchmark del framework CIS.

🏠 » CIS Control 12: Network Infrastructure Management »
12.2: Establish and Maintain a Secure Network Architecture

12.2: Establish and Maintain a Secure Network Architecture

Establish and maintain a secure network architecture. A secure network architecture must address segmentation, least privilege, and availability, at a minimum.

Asset Type	Security Function	Implementation Groups
Network	Protect	2, 3

Dependencies

- Safeguard 12.4: Establish and Maintain Architecture Diagram(s)
- Safeguard 2.1: Establish and Maintain a Software Inventory

Inputs

1. GV4 : Enterprise network architecture documentation
2. GV5 : Authorized software inventory

Operations

1. Use the network architecture GV4 to identify and enumerate the segments within the enterprise network GV36 (M1)
2. For each network segment identified in Operation 1, attempt to connect an unauthorized

🔗 latest

1 di 3

17/12/2024, 12:31

Figura 1.16: Dipendenze, input e operazioni nel framework CIS.

device

1. Identify and enumerate segments that allow you to connect unauthorized devices (M2)
2. Identify and enumerate segments that do not allow you to connect unauthorized devices (M3)
3. Use GV5 to identify authorized availability monitoring software
4. For eah network segment identified in Operation 1, determine whether an authorized availability monitoring software from Operation 3 covers the segment
 1. Identify and enumerate segments that are covered by availability monitoring software (M4)
 2. Identify and enumerate segments that are not covered by availability monitoring software (M5)

Measures

- M1 = Count of network segments within the enterprise
- M2 = Count of segments not compliant with least privilege
- M3 = Count of segments compliant with least privilege
- M4 = Count of segments monitored for availability
- M5 = Count of segments not monitored for availability

Metrics

Segmentation

Metric	If M1 is equal to 1, this metric is measured at a 0. Subsequent metrics can still be assessed.
Calculation	If M1 <= 1, Fail or If M1 >= 1, Pass

🔗 latest

2 di 3

17/12/2024, 12:33

Figura 1.17: Misure e metriche nel framework CIS.

Least Privilege

Metric	The percentage of network segments implementing least privilege
Calculation	M3 / M1

Availability

Metric	The percentage of network segments monitored for network availability
Calculation	M4 / M1

latest

3 di 3

17/12/2024, 12:33

Figura 1.18: Ulteriori metriche nel framework CIS.

del framework CIS. Questo lo rende un riferimento fondamentale per affrontare una vasta gamma di minacce informatiche, coprendo non solo le vulnerabilità tecniche, ma anche le strategie utilizzate dagli attaccanti in contesti diversi.

1.3.1 Overview di MITRE ATT&CK

MITRE ATT&CK è organizzato in una matrice che suddivide le informazioni in tre componenti principali:

- **Tattiche:** il "perché" di un attacco, ovvero gli obiettivi che gli attori delle minacce cercano di raggiungere
- **Tecniche:** il "come", ovvero i metodi specifici utilizzati per raggiungere tali obiettivi
- **Procedure:** esempi concreti basati su attacchi reali condotti da gruppi noti

Ciò che è stato descritto è mostrato nella figura 1.19.

Questa struttura consente alle organizzazioni di mappare ogni fase di un attacco informatico, dalle tattiche iniziali come il riconoscimento, alle fasi finali come l'esfiltrazione di dati.

Una particolarità molto apprezzata è che queste tre macrocategorie sono tutte a loro volta suddivise in base all'interesse del lettore: ognuna offre suggerimenti per

- **Imprese:** ha come target le aziende e le loro architetture, server, endpoint e reti
- **Dispositivi mobili:** ha come target i nostri telefoni, ovvero l'utente medio che è in cerca di consigli alla mano

Figura 1.19: Homepage del framework MITRE.

Figura 1.20: Schema delle categorie MITRE.

- **ICS (Sistemi di Controlli Industriali):** ha come target fabbriche, centrali elettriche, impianti e tutti gli ambienti professionali non strettamente legati all'informatica (nonostante sia gradito sicuramente un rimando a questo tipo di realtà, in tutta sincerità credo che un'azienda professionale non andrebbe a cercare soluzioni online ma si riferirebbe direttamente a dei professionisti)

Ciò che è stato descritto è mostrato nella figura 1.20.

MITRE ATT&CK si basa su dati concreti derivati da analisi di incidenti reali, ricerche accademiche e lavoro condiviso. Viene costantemente aggiornato per riflettere le minacce emergenti, garantendo così che rimanga rilevante e utile di fronte a un panorama di minacce in continua evoluzione.

MITRE si distingue per la sua **completezza e granularità**, offrendo informazioni dettagliate su ogni tecnica utilizzata dagli attaccanti, accompagnate da numerosi esempi concreti e suggerimenti di contromisure. Questa precisione lo rende uno strumento di valore inestimabile per analisti di sicurezza, red team (organizzazioni incaricate di simulare attacchi per individuare vulnerabilità informatiche) e professionisti dell'intelligence sulle minacce.

Uno dei punti di forza di ATT&CK è la capacità di illustrare ogni tecnica con una vasta gamma di esempi ripresi da eventi realmente accaduti. I fruitori possono vedere come le stesse vulnerabilità siano state sfruttate in contesti molto diversi tra loro, risultando in una consapevolezza sicuramente maggiore sull'insidiosità della minaccia. Ciò che è stato descritto è mostrato nella figura 1.21.

Questa diversità di casi evidenzia che le vulnerabilità informatiche non sono limitate a un settore o una dimensione aziendale specifica: anche realtà estremamente diverse possono trovarsi ad affrontare problemi simili, sottolineando l'importanza di soluzioni adattabili e proattive.

ATT&CK offre suggerimenti sia per l'individuazione che per la mitigazione di ogni tecnica elencata. Per quanto riguarda l'individuazione, OWASP risulta più chiaro e dettagliato, rendendolo una risorsa preferibile in questo ambito. Tuttavia, quando si tratta di mitigazione,

MITRE ATT&CK		Matrices	Tactics	Techniques	Defenses	CTI	Resources	Briefactors	Blog	Search
TECHNIQUES		Procedure Examples								
Exploit Public-Facing Application										
External Remote Services										
Hardware Additions										
Phishing										
Replication Through Removable Media										
Supply Chain Compromise										
Trusted Relationship										
Valid Accounts										
Execution										
Persistence										
Privilege Escalation										
Defense Evasion										
Credential Access										
Discovery										
Lateral Movement										
Collection										
Command and Control										
Exfiltration										
Impact										
Mobile										
ICS										

ID	Name	Description
C0028	2015 Ukraine Electric Power Attack	During the 2015 Ukraine Electric Power Attack, Sandworm Team installed a modified Dropbear SSH client as the backdoor to target systems. ^[1]
G1024	Akira	Akira uses compromised VPN accounts for initial access to victim networks. ^[2]
G0026	APT18	APT18 actors leverage legitimate credentials to log into external remote services. ^[3]
G0007	APT28	APT28 has used Tor and a variety of commercial VPN services to route brute force authentication attempts. ^[4]
G0016	APT29	APT29 has used compromised identities to access networks via VPNs and Citrix. ^{[5][6]}
G0096	APT41	APT41 compromised an online billing/payment service using VPN access between a third-party service provider and the targeted payment service. ^{[7][8]}
C0027	C0027	During C0027, Scattered Spider used Citrix and VPNs to persist in compromised environments. ^[9]
C0032	C0032	During the C0032 campaign, TEMPVoles used VPN access to persist in the victim environment. ^[10]
G0114	Chimera	Chimera has used legitimate credentials to login to an external VPN, Citrix, SSH, and other remote services. ^{[11][12]}
C0004	CostaRico	During CostaRico, the threat actors set up remote tunneling using an SSH tool to maintain access to a compromised environment. ^[13]
S0000	Doki	Doki was executed through an open Docker daemon API port. ^[14]
G0035	Dragonfly	Dragonfly has used VPNs and Outlook Web Access (OWA) to maintain access to victim networks. ^{[15][16]}
G1003	Ember Bear	Ember Bear have used VPNs both for initial access to victim environments and for persistence within them following compromise. ^[17]
G1016	FIN13	FIN13 has gained access to compromised environments via remote access services such as the corporate virtual private network (VPN). ^[18]

Figura 1.21: Esempi di procedura nel framework MITRE.

MITRE ATT&CK		Matrices	Tactics	Techniques	Defenses	CTI	Resources	Briefactors	Blog	Search
TECHNIQUES		Mitigations								
Exploit Public-Facing Application										
External Remote Services										
Hardware Additions										
Phishing										
Replication Through Removable Media										
Supply Chain Compromise										
Trusted Relationship										
Valid Accounts										
Execution										
Persistence										
Privilege Escalation										
Defense Evasion										
Credential Access										
Discovery										
Lateral Movement										
Collection										
Command and Control										
Exfiltration										
Impact										
Mobile										
ICS										

ID	Mitigation	Description
M1042	Disable or Remove Feature or Program	Disable or block remotely available services that may be unnecessary.
M1035	Limit Access to Resource Over Network	Limit access to remote services through centrally managed concentrators such as VPNs and other managed remote access systems.
M1032	Multi-factor Authentication	Use strong two factor or multi factor authentication for remote service accounts to mitigate an adversary's ability to leverage stolen credentials, but be aware of Multi-Factor Authentication Interception techniques for some two factor authentication implementations.
M1030	Network Segmentation	Deny direct remote access to internal systems through the use of network proxies, gateways, and firewalls.

ID	Data Source	Data Component	Detects
D50015	Application Log	Application Log Content	When authentication is not required to access an exposed remote service, monitor for follow-on activities such as anomalous external use of the exposed API or application.
D50028	Login Session	Login Session Metadata	Follow best practices for detecting adversary use of Valid Accounts for authenticating to remote services. Collect authentication logs and analyze for unusual access patterns, windows of activity, and access outside of normal business hours.
D50029	Network Traffic	Network Connection Creation	Monitor for newly constructed network connections that may use Valid Accounts to access and/or persist within a network using External Remote Services. Use of External Remote Services may be legitimate depending on the environment and how it's used. Other factors, such as access patterns and activity that occurs after a remote login, may indicate suspicious or malicious behavior using External Remote Services.
		Network Traffic Content	Monitor and analyze traffic patterns and packet inspection associated to protocol(s) that do not follow the expected protocol standards and traffic flows (e.g. extraneous packets that do not belong to established flows, gratuitous or anomalous traffic patterns, anomalous syntax, or structure). Consider correlation with process monitoring and command line to detect anomalous processes execution and command line arguments associated to traffic patterns (e.g. monitor connections to use of files that do not normally initiate connections for connections).

Figura 1.22: Mitigazione e rilevamento nel framework MITRE.

OWASP si posiziona come la risorsa meno efficace, con indicazioni spesso troppo generiche. In confronto, ATT&CK offre suggerimenti più concreti e utili, sebbene ancora sintetici e non sempre esaustivi come riscontriamo invece nel caso di CIS. Ciò che è stato descritto è mostrato nella figura 1.22.

Un ulteriore elemento distintivo di MITRE ATT&CK è la sua attenzione alla documentazione. Alla fine di ogni pagina dedicata a una tecnica o un attacco, il framework elenca tutte le referenze rilevanti, senza limitarsi a poche fonti principali. Questo approccio esaustivo permette agli utenti di accedere a una profondità di informazioni raramente disponibile altrove. È comune trovare decine, se non centinaia, di referenze, garantendo una panoramica completa delle basi teoriche e pratiche dietro ogni tecnica documentata. Ciò che è stato descritto è mostrato nella figura 1.23.

Il sito è pensato per essere semplice e intuitivo, perfetto sia per chi vuole curiosare senza troppe complicazioni, sia per chi cerca informazioni più tecniche e approfondite. A differenza del sito di CIS, che lascia parecchio a desiderare a causa della sua struttura poco funzionale, MITRE offre un'esperienza di navigazione chiara e piacevole, così da rendere la navigazione più facile, chiara e veloce per chiunque.

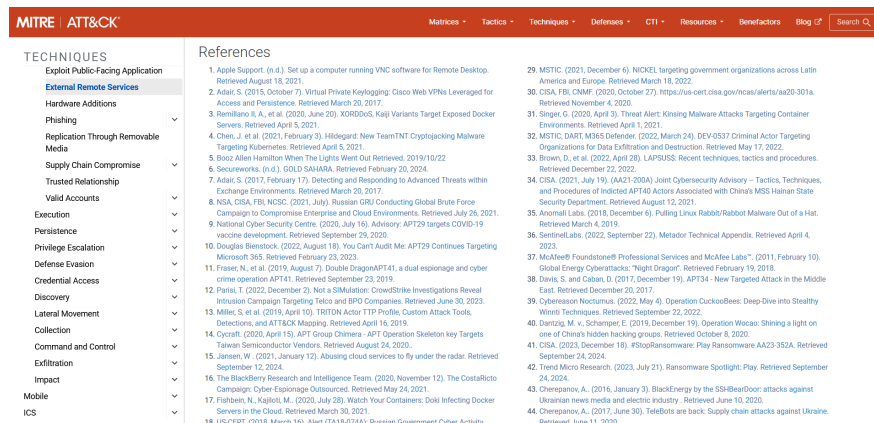


Figura 1.23: Riferimenti nel framework MITRE.

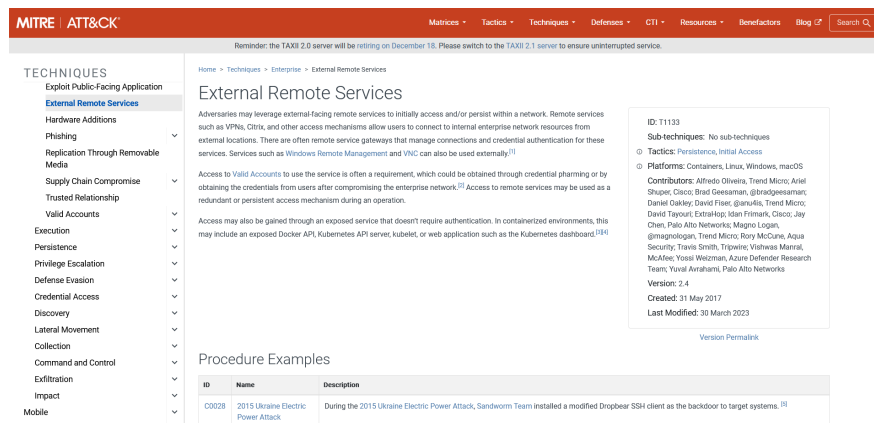


Figura 1.24: Riepilogo del framework MITRE.

1.3.2 Analisi dei difetti di MITRE ATT&CK

Nonostante la sua utilità, il framework MITRE ATT&CK può risultare **complesso da utilizzare** per le organizzazioni con competenze limitate in materia di cybersecurity: nonostante fornisca documentazione molto più accurata di quanto possa fare un CIS Controls, ha strumenti di implementazione molto più risicati di come può essere il CIS Benchmarks: i consigli in quanto a prevenzione e protezione sono quasi sempre superficiali per un lettore alle prime armi e sicuramente troppo vaghi per un lettore esperto. Ciò che è stato descritto è mostrato nella figura 1.22.

Nonostante il paragrafo iniziale di ogni capitolo sia concepito appositamente per fornire una panoramica generale della minaccia trattata, e pur assumendo che questo sia chiaro e completo, l'assenza totale di frammenti di codice o immagini esplicative all'interno dell'intero sito potrebbe lasciare perplessi alcuni lettori, soprattutto quelli più interessati ai dettagli o con una maggiore predisposizione all'apprendimento visivo. Questa mancanza potrebbe talvolta suscitare dubbi o lasciare alcune domande irrisolte nella mente del lettore. Ciò che è stato descritto è mostrato nella figura 1.24.

Un'altra problematica che ATT&CK, come CIS, presenta è la mancanza di strumenti pratici per identificare le vulnerabilità, come potrebbe essere ZAP. Questo rende il sito inadatto sia

come supporto nella scoperta delle minacce all'interno del proprio sistema, sia come strumento per la loro risoluzione. Si potrebbe quindi concludere che MITRE ATT&CK funzioni più come un'enciclopedia delle vulnerabilità informatiche, dedicata esclusivamente alla conoscenza di queste ultime e a come abbiano causato problemi in passato, anche ad organizzazioni di rilievo. Pur offrendo un'idea generale di risoluzione, non approfondisce gli aspetti pratici per metterla in atto.

Capitolo 2

Confronto tra i Framework di Sicurezza

In questo capitolo verranno confrontati i framework OWASP, CIS e MITRE ATT&CK, mettendo in luce i punti di forza di ciascuno e suggerendo un'ipotetica combinazione ideale dei loro pregi.

2.1 Confronto dei principali aspetti

Chiarezza espositiva delle vulnerabilità

OWASP si distingue per la sua chiarezza e semplicità espositiva, offrendo spiegazioni dettagliate e arricchendo il contenuto con strumenti visivi come frammenti di codice e immagini, che agevolano la comprensione. Tuttavia, questa attenzione meticolosa alla spiegazione può talvolta risultare ridondante: per assicurarsi che ogni concetto sia pienamente assimilato, alcune idee vengono ripetute più volte, rendendo il contenuto talvolta prolisso. Ciò che è stato descritto è mostrato nelle figure 2.1, 2.2 e 2.3.

MITRE adotta invece un approccio diametralmente opposto, concentrandosi sull'essenziale. Si impegna a fornire una panoramica completa degli aspetti fondamentali della sicurezza

Types of MFA

MFA means that *at least* two of the following factors are required to authentication:

Factor	Examples
Something You Know	Passwords, PINs and security questions.
Something You Have	Hardware or software tokens, certificates, email*, SMS, and phone calls.
Something You Are	Fingerprints, facial recognition, iris scans, handprint scans and behavioural factors.
Location	Source IP ranges, and geolocation.

* Email only really constitutes "something you have" if the email account itself is protected with MFA. As such, it should be considered weaker than other alternatives such as certificates or TOTP, and may not be accepted as MFA under some definitions.

Note that requiring multiple examples of a single factor (such as needing both a password and a PIN) **does not constitute MFA**, although it may provide some security benefits over a simple password, and may be considered two-step verification (2SV).

Due to the complexity of implementing biometrics in a browser-based environment, "Something You Are" is rarely used for web applications, although it is starting to be adopted using standards such as WebAuthn. The most common second factor is "Something You Have".

Figura 2.1: Autenticazione multi-fattore (MFA) nel framework OWASP.

MFA Reset Process

If the application implements an MFA reset process, this should be tested in the same way that the [password reset process](#) is tested. It is important that this process is *at least* as strong as the MFA implementation for the application.

Alternative Authentication

Some applications will allow the user to prove their identity through other means, such as the use of [security questions](#). This usually represents a significant weakness, as security questions provide a far lower level of security than MFA.

One-Time Passwords

The most common form of MFA is the one of One-Time Passwords (OTPs), which are typically six-digit numeric codes (although they can be longer or shorter). These can either be generated by both the server and the user (for example, with an authenticator app), or can be generated on the server and sent to the user. There are various ways that this OTP can be provided to the user, including:

Type	Description
HMAC One-Time Password (HOPT)	Generates a code based on the HMAC of a secret and a shared counter.
Time-based One-Time Password (TOTP)	Generates a code based on HMAC of a secret and the current time.
Email	Sends a code via email.
SMS	Sends a code via SMS.
Phone	Sends a code via a voice call to a phone number.

The OTP is typically entered after the user has provided their username and password. There are various checks that should be performed, including:

- Is the account locked out after multiple failed MFA attempts?
- Is the user's IP address blocked after multiple failed MFA attempts across different accounts?
- Are failed MFA attempts logged?
- Is the form vulnerable to injection attacks, including [SQL wildcard injection](#)?

Figura 2.2: Esempio di configurazione MFA nel framework OWASP.

HOTP and TOTP

HOTP and TOTP codes are both based on a secret that is shared between the server and the user. For TOTP codes, this is usually provided to the user in the form of a QR code that they scan with an authenticator app (although it can also be provided as a text secret for them to manually enter).

Where the secret is generated on the server, it should be checked to ensure that it is sufficiently long and complex ([RFC 4226](#) recommends at least 160 bits), and that it is generated using a [secure random function](#).

Where the secret can be provided by the user, an appropriate minimum length should be enforced, and the input should be checked for the usual injection attacks.

TOTP codes are typically valid for 30 seconds, but some applications choose to accept multiple codes (such as the previous, current, and next codes) in order to deal with differences between the system time on the server and on the user's device. Some applications may allow multiple codes on either side of the current one, which may make it easier for an attacker to guess or brute-force the code. The table below shows the chance of successfully brute-forcing an OTP code based on an attacker being able to make 10 requests a second, for applications that accept either only the current code, or multiple codes (see [this article](#) for the calculations behind the table).

Valid Codes	Success rate after 1 hour	Success rate after 4 hours	Success rate after 12 hours	Success rate after 24 hours
1	4%	13%	35%	58%
3	10%	35%	72%	92%
5	16%	51%	88%	99%
7	22%	63%	95%	99%

Figura 2.3: Flusso di autenticazione MFA nel framework OWASP.

Multi-Factor Authentication Interception

Adversaries may target multi-factor authentication (MFA) mechanisms, (i.e., smart cards, token generators, etc.) to gain access to credentials that can be used to access systems, services, and network resources. Use of MFA is recommended and provides a higher level of security than usernames and passwords alone, but organizations should be aware of techniques that could be used to intercept and bypass these security mechanisms.

If a smart card is used for multi-factor authentication, then a keylogger will need to be used to obtain the password associated with a smart card during normal use. With both an inserted card and access to the smart card password, an adversary can connect to a network resource using the infected system to proxy the authentication with the inserted hardware token. ^[1]

Adversaries may also employ a keylogger to similarly target other hardware tokens, such as RSA SecurID. Capturing token input (including a user's personal identification code) may provide temporary access (i.e. replay the one-time passcode until the next value rollover) as well as possibly enabling adversaries to reliably predict future authentication values (given access to both the algorithm and any seed values used to generate appended temporary codes). ^[2]

Other methods of MFA may be intercepted and used by an adversary to authenticate. It is common for one-time codes to be sent via out-of-band communications (email, SMS). If the device and/or service is not secured, then it may be vulnerable to interception. Service providers can also be targeted: for example, an adversary may compromise an SMS messaging service in order to steal MFA codes sent to users' phones. ^[3]

Figura 2.4: Autenticazione multi-fattore (MFA) nel framework MITRE.

6.3: Require MFA for Externally-Exposed Applications

Require all externally-exposed enterprise or third-party applications to enforce MFA, where supported. Enforcing MFA through a directory service or SSO provider is a satisfactory implementation of this Safeguard.

Figura 2.5: Autenticazione multi-fattore (MFA) nel framework CIS.

informatica, evitando di cadere sia nel perfezionismo eccessivo sia nella monotonia, puntando a un'esposizione sintetica ma efficace. Ciò che è stato descritto è mostrato nella figura 2.4.

Il CIS, con i suoi CIS Controls, partecipa a questa competizione, ma si posiziona nettamente dietro rispetto agli altri due in termini di lunghezza e precisione nell'esposizione. Ciò che è stato descritto è mostrato nella figura 2.5.

Completezza delle informazioni

In termini di completezza rispetto al proprio obiettivo, ritengo che OWASP si distingua, seppur di poco, rispetto agli altri due. Questo perché OWASP si pone un obiettivo, per certi aspetti, più concreto: concentrarsi sulla copertura completa delle applicazioni web. Al contrario, gli altri due, mirano a garantire la sicurezza di qualsiasi sistema informatico. Un obiettivo così ampio, inevitabilmente, li porta a essere meno focalizzati sui dettagli specifici che OWASP, invece, può approfondire con maggiore attenzione.

Per chiarire meglio il punto, voglio proporre due esempi, magari semplici, ma che evidenziano lo spazio di miglioramento degli altri due. MITRE, volendo coprire ogni tipo di vulnerabilità informatica, dovrebbe, almeno in teoria, includere tutto ciò che OWASP affronta con pari precisione, ma di fatto non lo fa. CIS, invece, con i suoi Benchmarks, punta a mettere in sicurezza qualsiasi dispositivo informatico. Tuttavia, come possiamo notare nella sezione dedicata ai software desktop, vengono trattati solamente alcuni principali software, lasciando

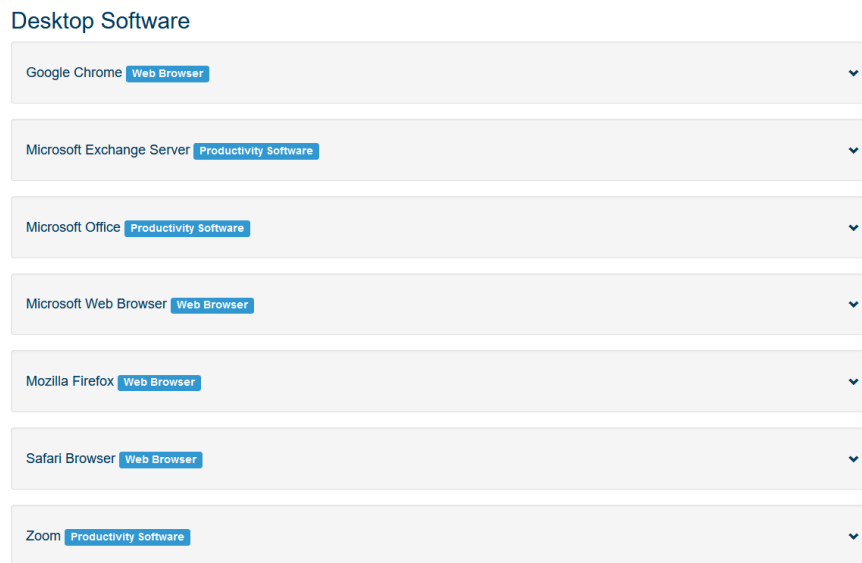


Figura 2.6: Software desktop nel framework CIS.

fuori grandi realtà come possono essere Opera, Photoshop o Blender. Ciò che è stato descritto è mostrato nella figura 2.6.

Per quanto riguarda lo spirito di completezza con il quale viene affrontato ogni capitolo, in realtà tutti e tre i framework non hanno nulla da invidiare agli altri. Ognuno di loro, nella propria area di competenza, spicca incredibilmente: OWASP tratta per filo e per segno tutto ciò che riguarda le applicazioni web; MITRE ATT&CK, d'altra parte, si distingue per la documentazione granulare e per la sua copertura di una vasta gamma di minacce informatiche, risultando il riferimento più completo in termini di ampiezza e profondità delle informazioni; CIS Benchmarks si concentra invece sulla configurazione sicura di sistemi operativi, software e dispositivi, offrendo un livello di dettaglio specifico che non si trova in OWASP o MITRE.

In definitiva, ciascuno dei tre framework contribuisce in modo significativo alla sicurezza informatica, ma con approcci e ambiti di applicazione distinti: OWASP per le applicazioni web, MITRE per le minacce globali e CIS per la configurazione sicura dei sistemi. Questa specializzazione rende i tre strumenti complementari piuttosto che concorrenti.

Strumenti e risorse pratiche

Il framework OWASP è rinomato per il suo approccio pratico alla sicurezza informatica, grazie alla disponibilità di strumenti concreti come OWASP ZAP (Zed Attack Proxy). ZAP, un software open source ampiamente utilizzato, consente di individuare vulnerabilità nelle applicazioni web, operando come un proxy "man-in-the-middle" in grado di intercettare e analizzare il traffico tra browser e server. Questo strumento offre sia scansioni passive, che analizzano il traffico senza alterarlo, sia scansioni attive, capaci di identificare vulnerabilità quali SQL injection, cross-site scripting (XSS) e configurazioni non sicure. La sua interfaccia intuitiva lo rende accessibile anche ai meno esperti, mentre le opzioni avanzate e la possibilità di personalizzazione ne fanno una risorsa potente per professionisti del settore. Accanto a ZAP, OWASP supporta gli utenti con una vasta gamma di risorse educative, tra cui documentazione dettagliata-

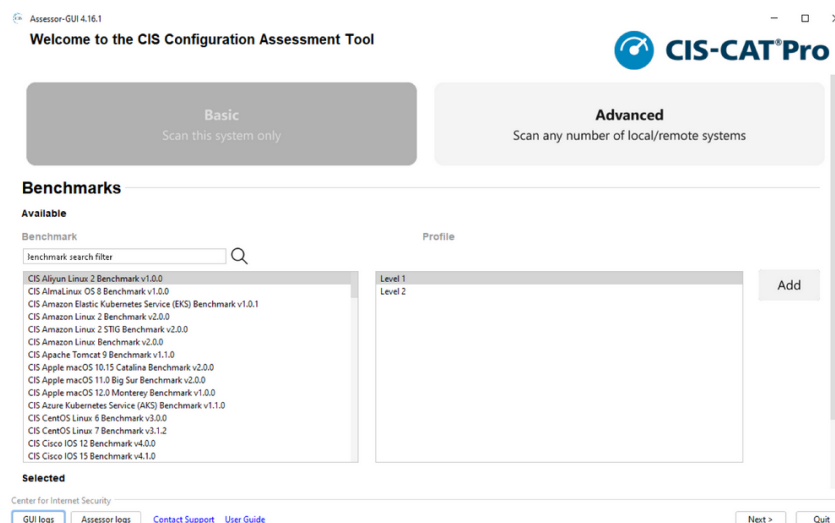


Figura 2.7: CIS CAT.

ta, tutorial e forum attivi, creando un ecosistema che combina strumenti operativi e opportunità di apprendimento. Ciò che è stato descritto è mostrato nella figura 1.1.

Parallelamente, il Center for Internet Security propone strumenti di analisi come CIS-CAT, concepiti per agevolare l'adozione dei CIS Benchmarks, standard riconosciuti per migliorare la sicurezza dei sistemi. CIS-CAT, disponibile in una versione gratuita e in una a pagamento, consente di confrontare le configurazioni di un sistema con quelle raccomandate, fornendo report dettagliati e feedback chiari per facilitare il raggiungimento della conformità. Grazie alla sua capacità di adattarsi a diversi contesti, CIS-CAT rappresenta una risorsa fondamentale per aziende, istituzioni governative e accademiche impegnate nella protezione delle proprie infrastrutture. Ciò che è stato descritto è mostrato nella figura 2.7.

Infine, MITRE ATT&CK si distingue come una base di conoscenza cruciale per la sicurezza informatica. Non si presenta come uno strumento operativo ma come un framework di riferimento che mappa tattiche, tecniche e procedure (TTP) utilizzate da attori di minacce. La sua ampia adozione ha portato a integrarlo in strumenti avanzati come piattaforme EDR e XDR, migliorandone la capacità di rilevamento e risposta agli incidenti. MITRE ha anche sviluppato CALDERA, una piattaforma open source per simulare attacchi informatici basati sul framework ATT&CK, fornendo uno strumento pratico per testare la resilienza dei sistemi. Sebbene diversi per approccio e finalità, OWASP, CIS e MITRE rappresentano pilastri complementari per affrontare le sfide della sicurezza informatica moderna, offrendo strumenti pratici, standard rigorosi e conoscenze strategiche. Ciò che è stato descritto è mostrato nella figura 2.8.

Aggiornamento e mantenimento

Il Web Security Testing Guide (WSTG) dell'OWASP è un progetto open source che fornisce linee guida complete per testare la sicurezza delle applicazioni web e dei servizi web. Gli aggiornamenti al WSTG non seguono un calendario fisso, ma dipendono dall'impegno dei volontari e dalle esigenze emergenti nel campo della sicurezza delle applicazioni web. In ogni caso, per dare un'idea generale, la versione 4.0 è stata rilasciata il 17 settembre 2014, seguita

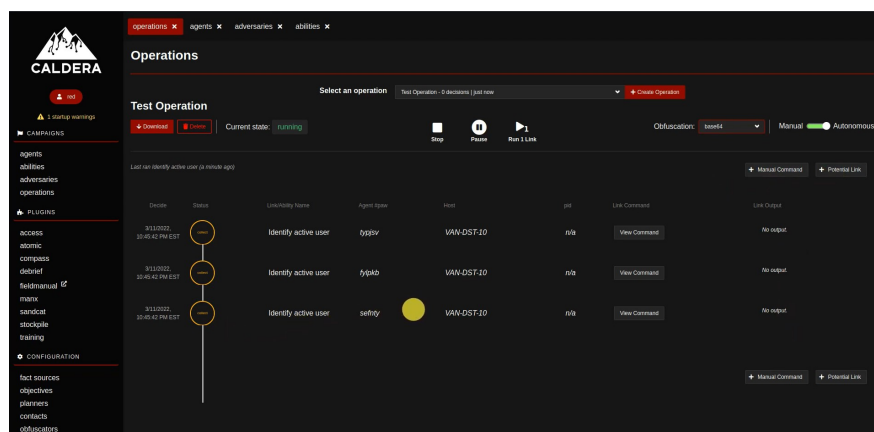


Figura 2.8: MITRE CALDERA.

dalla versione 4.1 il 21 aprile 2020 e dalla versione 4.2 il 3 dicembre 2020. Attualmente, il team sta lavorando alla versione 5.0. L'aggiornamento dell'OWASP Top 10 invece avviene ogni 3-4 anni in base allo sviluppo delle vulnerabilità informatiche.

Il MITRE ATT&CK, invece, viene aggiornato tipicamente due volte l'anno, con nuove versioni rilasciate ogni sei mesi. Ad esempio, la versione 16 è stata rilasciata il 31 ottobre 2024, mentre la versione 15 è stata pubblicata il 23 aprile 2024. La maggiore frequenza di lavoro è data sia dal bacino più ampio che devono coprire, sia dal fatto che è una no-profit e non un sito open-source. Gli addetti alla ricerca sono dunque pagati e sicuramente in questo modo lavorano più velocemente di persone che lo fanno per pura passione.

Infine i CIS Controls vengono aggiornati in base all'evoluzione delle minacce informatiche e alle esigenze della comunità. Ad esempio, la versione 8.0 è stata rilasciata nel maggio 2021, seguita da un aggiornamento alla versione 8.1 nel 2023. La storia è un po' diversa per i benchmarks che vengono perfezionati molto più sovente: per loro si parla di aggiornamenti mensili o trimestrali.

Usabilità

Tra i framework analizzati, MITRE ATT&CK risulta il più accessibile e intuitivo. La sua struttura modulare e ben organizzata consente un'immediata comprensione delle minacce e delle tecniche di attacco, facilitando la navigazione anche a chi si avvicina per la prima volta al mondo della sicurezza informatica. Le informazioni sono presentate con un livello di sintesi equilibrato, senza compromettere la profondità dei contenuti, il che rende MITRE uno strumento estremamente facile da consultare e applicare.

OWASP, pur mantenendo una notevole semplicità d'uso, si distingue per un'interfaccia chiara e per l'abbondanza di risorse didattiche che ne facilitano l'apprendimento. L'inclusione di esempi pratici, diagrammi e codice esemplificativo contribuisce ulteriormente alla comprensibilità del framework, rendendolo particolarmente indicato per chi desidera approfondire in modo graduale e progressivo la sicurezza delle applicazioni web.

CIS, per quanto riguarda i benchmark, risulta intuitivo e semplice da utilizzare al pari dei suoi concorrenti. Tuttavia, i CIS Controls e la struttura complessiva del sito si rivelano articolati e di difficile comprensione. La disposizione non lineare delle risorse può disorientare l'utente,

richiedendo un impegno significativo e un'attenzione prolungata per sfruttare appieno tutte le risorse disponibili. Questo rende CIS meno immediato rispetto a MITRE e OWASP.

Limitazioni

Ogni framework analizzato, pur eccellendo in determinati ambiti, presenta alcune limitazioni che ne riducono l'efficacia in contesti specifici.

OWASP, nonostante la completezza e la chiarezza delle sue risorse, si concentra esclusivamente sulla sicurezza delle applicazioni web, tralasciando altri aspetti fondamentali della cybersecurity, come la sicurezza dei sistemi operativi o delle reti. Inoltre, la quantità di dettagli e la ridondanza di alcune spiegazioni possono risultare dispersive, specialmente per utenti con esperienza avanzata che cercano informazioni concise e dirette. Tuttavia, per chi si occupa specificamente di applicazioni web, OWASP rappresenta un riferimento insostituibile per la comprensione delle vulnerabilità più comuni e delle strategie di mitigazione.

MITRE ATT&CK, pur essendo un riferimento globale per l'identificazione e la classificazione delle minacce, non fornisce strumenti operativi diretti per mitigare le vulnerabilità. È più una base di conoscenza che un insieme di linee guida pratiche, il che può renderlo meno immediato per chi cerca indicazioni operative e soluzioni concrete. Tuttavia, la sua granularità e la capacità di descrivere tecniche specifiche lo rendono un'ottima risorsa per l'analisi dettagliata delle minacce e la pianificazione di difese avanzate.

Il framework CIS, sebbene offra controlli e benchmark dettagliati, si concentra maggiormente sulla conformità piuttosto che sulla gestione delle minacce in tempo reale. Inoltre, la documentazione può risultare poco intuitiva per chi è alle prime armi, e alcuni dei suoi benchmark tendono a essere generici, escludendo software meno diffusi ma comunque vulnerabili. Tuttavia, la copertura ampia e la continua revisione dei benchmark garantiscono un livello di protezione elevato per la maggior parte degli ambienti IT.

Capitolo 3

L'utopia di un Documento di Sicurezza Universale

Nel corso di questa tesi, abbiamo analizzato in dettaglio tre dei principali framework di sicurezza informatica: OWASP, MITRE ATT&CK e CIS Benchmarks. Ciascuno di essi rappresenta un pilastro importante nella gestione della sicurezza, seppur con approcci differenti e complementari. Questa analisi comparativa ha evidenziato come nessuno di questi framework sia completamente autosufficiente, ma come un ideale documento di sicurezza universale possa nascere dall'integrazione armonica dei loro punti di forza.

Unendo i pregi di questi framework, un sistema ideale dovrebbe:

- Offrire la **chiarezza espositiva di OWASP**, con spiegazioni dettagliate arricchite da frammenti di codice, immagini e risorse pratiche che guidino il lettore attraverso l'intero ciclo di vita della sicurezza.
- Garantire la **completezza e granularità di MITRE ATT&CK**, includendo riferimenti specifici a tattiche, tecniche e procedure documentate per un'analisi strutturata delle minacce.
- Integrare **guide pratiche e configurazioni dettagliate**, come quelle fornite dai CIS Benchmarks, che indicano come implementare controlli di sicurezza concreti e **verificabili** grazie ai CIS-CAT.
- Fornire **strumenti operativi per test e verifica**, come OWASP ZAP, per validare le contromisure adottate in un ambiente sicuro.
- Coprire una vasta gamma di contesti, dalle applicazioni web ai sistemi operativi, fino alle infrastrutture critiche, per garantire un approccio **olistico alla sicurezza**.
- Creare una **pagina web o un'applicazione ad hoc** nella quale provare i metodi di test studiati nel capitolo appena letto.
- Implementare uno strumento come **MITRE CALDERA** per creare attacchi simulati e verificare la resistenza del sistema alle minacce.
- Adottare una **struttura modulare e scalabile**, ispirandosi a MITRE ATT&CK, consentendo un adattamento del framework a esigenze specifiche e settoriali.

- Supportare utenti di diversi livelli di competenza, includendo risorse introduttive per principianti e approfondimenti tecnici per esperti.

Un framework così concepito risulterebbe **completo, pratico e adattabile**, offrendo una soluzione unica per la gestione della sicurezza informatica.

Tuttavia, l'utopia di un documento di sicurezza universale non può prescindere da alcune verità fondamentali della sicurezza:

“L'unico codice sicuro è quello che non viene mai scritto.”

Questa massima sottolinea come ogni linea di codice aggiunta aumenti la superficie di attacco potenziale di un sistema. La sicurezza di un sistema dipende dalla solidità del suo anello più fragile. Non esistono soluzioni assolute: un singolo punto debole può compromettere l'intero sistema.

Questi principi ci portano a una riflessione cruciale: è meglio seguire scrupolosamente un documento di sicurezza come quelli appena analizzati, con la convinzione che la sua adozione renda il proprio codice infallibile, oppure non seguirlo, mantenendo però la consapevolezza che ogni software scritto può sempre presentare vulnerabilità latenti?

Un documento di sicurezza universale dovrebbe forse proprio lasciare aperta questa riflessione, non per instillare dubbio, ma per mantenere viva la consapevolezza critica che la sicurezza non è mai un traguardo definitivo, ma un **processo continuo di apprendimento e adattamento**.

Conclusioni

In conclusione, la rapidità dell'evoluzione tecnologica, che in meno di un secolo ci ha portati da macchinari rudimentali come l'ENIAC a dispositivi tascabili e potenti come gli smartphone, rappresenta un fenomeno di portata straordinaria. Tuttavia, questo progresso non è privo di complessità: la velocità con cui emergono nuove tecnologie mette costantemente alla prova la capacità di adattamento dell'uomo, rendendo indispensabile un aggiornamento continuo delle competenze e delle strategie di sicurezza.

L'interconnessione globale e l'obsolescenza rapida di molti dispositivi, come nel caso degli smartphone, evidenziano come la corsa all'innovazione possa aumentare le vulnerabilità digitali, soprattutto quando le misure di sicurezza non riescono a stare al passo con l'evoluzione tecnologica. L'integrazione di Intelligenza Artificiale e la diffusione dell'Internet delle Cose, se da un lato offrono strumenti di protezione sempre più avanzati, dall'altro ampliano i potenziali punti di attacco, con conseguenze che possono estendersi ben oltre l'individuo, coinvolgendo reti complesse e infrastrutture critiche.

Alla luce di queste sfide, risulta essenziale un approccio più responsabile all'innovazione, in cui il progresso tecnologico sia accompagnato da un impegno costante nella sicurezza e nella formazione continua. Non si tratta di rallentare l'innovazione, ma di gestirla con consapevolezza, affinché i benefici che essa porta possano essere goduti in modo sicuro e sostenibile. Solo così potremo affrontare il futuro con fiducia, garantendo che la tecnologia rimanga uno strumento al servizio del benessere collettivo e non un fattore di vulnerabilità crescente.

Appendici

Durante lo studio del documento WSTG di OWASP, ho riscontrato molte ridondanze e ho individuato alcuni modi per migliorare la lettura, rendendola più piacevole, semplice e comprensibile.

- **Riformulazione_OWASP:** Documento completo, riformulato in modo più comprensibile. Link: https://github.com/filograzzo/Tesi_Triennale_Cybersecurity/blob/main/Appendici/Riformulazione_OWASP.md
- **Strumenti:** Una lista degli strumenti utilizzati negli esempi proposti dal documento. Link: https://github.com/filograzzo/Tesi_Triennale_Cybersecurity/blob/main/Appendici/Strumenti.md
- **Programmatori:** Consigli tratti dal documento completo, pensati per i programmatori. In questo documento non vengono fornite spiegazioni, ma solo linee guida. Chi fosse interessato a entrare più nello specifico di uno di questi consigli può facilmente trovarli nel documento completo grazie alla numerazione dei capitoli. Link: https://github.com/filograzzo/Tesi_Triennale_Cybersecurity/blob/main/Appendici/Programmatori.md

Bibliografia

Siti internet:

- **OWASP:** <https://owasp.org/>
 - **OWASP Top 10:** <https://owasp.org/www-project-top-ten/>
 - **OWASP wstg:** <https://github.com/OWASP/wstg/tree/master/document>
 - **OWASP ZAP:** <https://www.zaproxy.org/>
- **CIS:** <https://www.cisecurity.org/>
 - **CIS Controls:** <https://controls-assessment-specification.readthedocs.io/en/latest/>
 - **CIS Benchmarks:** <https://downloads.cisecurity.org/#/>
- **MITRE ATT&CK:** <https://attack.mitre.org/>
 - **MITRE CALDERA:** <https://caldera.mitre.org/>

Ringraziamenti

Ai miei genitori, che non hanno mai smesso di credere in me, anche nei momenti in cui facevo fatica a credere in me stesso.

A mio fratello, che mi ricorda ogni giorno di quanto sia importante inseguire i propri sogni.

Ai miei amici, che mi riescono a confortare anche restando in silenzio.

E infine a me stesso, per non essermi mai dato per vinto.